Applied Cryptography
Lect. #4

Marco Calderini

University of Trento

A.Y. 2024/2025

Last time:

- Stream ciphers

This time:

- Block ciphers

Pseudo Random Functions and Permutations

Definition

- Deterministic cipher $\mathcal{E} = (Enc, Dec)$
- $\mathcal{P} = \mathcal{C} = \mathcal{X}$
- fixed $k \in \mathcal{K}$, $Enc(k, \cdot) = F_k : \mathcal{X} \to \mathcal{X}$ is a permutation

A **block cipher** is a set of permutations individuated by $k \in \mathcal{K}$, $\{F_k : k \in \mathcal{K}\}$.

Note: Block ciphers are also called Pseudo Random Permutation (PRP).

Pseudo Random Function

Moere in general, **Pseudo Random Function** (PRF) is a function F defined over $(\mathcal{K}, \mathcal{X}, \mathcal{Y})$:

$$F : \mathcal{K} \times \mathcal{X} \to \mathcal{Y}$$

Note: PRPs are PRFs such that $\mathcal{X} = \mathcal{Y}$ and F_k is a permutation for any $k \in \mathcal{K}$

Security for block ciphers

A secure block cipher (or PRP) should be computationally indistinguishable from a truly random permutation.

Let $Perms[\mathcal{X}]$ be the set of all permutations on $\mathcal{X}$.

Note: $|Perms[\mathcal{X}]| = |\mathcal{X}|!$.

Example

$\mathcal{X} = GF(2)^{128}$, then $|Perms[\mathcal{X}]| \approx 2^{2^{135}}$

The block cipher AES-128 is a set of 2^{128} permutations

Attack Game (BC)

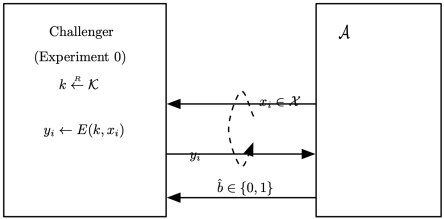
Let $\mathcal{E} = (Enc, Dec)$, a block cipher, and $\mathcal{A}$ an adversary. We define two experiments, Experiment 0 and Experiment 1. For $b = 0, 1$, we define:

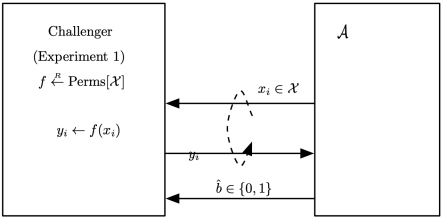
Experiment b**:**

- The challenger selects $f \in Perms[\mathcal{X}]$ as follow:
  - if $b = 0$, $k \xleftarrow{R} \mathcal{K}$, $f = Enc_k$,
  - if $b = 1$, $f \xleftarrow{R} Perms[\mathcal{X}]$
- $\mathcal{A}$ submits a sequence of queries to the challenger. For $i = 1, 2, \ldots$. ith query is $x_i \in \mathcal{X}$ and the challenger replies with $y_i = f(x_i)$
- $\mathcal{A}$ outputs $\hat{b} \in \{0, 1\}$.

Let W_b be the event that $\mathcal{A}$ outputs 1 in Experiment b. We define $BCadv[\mathcal{A}, \mathcal{E}] = |Pr[W_0] - Pr[W_1]|$

Note: $\mathcal{A}$ is a Q-query BC adversary if $\mathcal{A}$ issues at most Q queries. For efficient adv. Q is poly-bounded.


Challenger
(Experiment 0)
$k \xleftarrow{R} \mathcal{K}$
$y_i \leftarrow E(k, x_i)$
$\mathcal{A}$
$x_i \in \mathcal{X}$
y_i
$\hat{b} \in \{0, 1\}$


Challenger
(Experiment 1)
$f \xleftarrow{R} \mathrm{Perms}[\mathcal{X}]$
$y_i \leftarrow f(x_i)$
$\mathcal{A}$
$x_i \in \mathcal{X}$
y_i
$\hat{b} \in \{0, 1\}$

Definition

A block cipher $\mathcal{E}$ is secure if for all efficient adversaries $\mathcal{A}$, the value $BCadv[\mathcal{A}, \mathcal{E}]$ is negligible.

Remark (bit-guessing game)

$\mathcal{A}$'s bit-guessing advantage $BCadv^*[\mathcal{A}, \mathcal{E}] = |Pr[\hat{b} = b] - 1/2|$.
$BCadv[\mathcal{A}, \mathcal{E}] = 2 \cdot BCadv^*[\mathcal{A}, \mathcal{E}]$

Example

Let $\mathcal{X} = \{0, 1\}$. $Perms[\mathcal{X}]$ contains two functions.

Consider the following PRP:
key space $\mathcal{K} = \{0, 1\}$, input space $\mathcal{X} = \{0, 1\}$
PRP defined as:

$$E(k, x) = x \oplus k$$

Is this a secure PRP?

Example

Let $\mathcal{X} = \{0, 1\}$. $Perms[\mathcal{X}]$ contains two functions.

Consider the following PRP:
key space $\mathcal{K} = \{0, 1\}$, input space $\mathcal{X} = \{0, 1\}$
PRP defined as:

$$E(k, x) = x \oplus k$$

Is this a secure PRP?
Yes

Some implications of security

- A secure block cipher is unpredictable ($|\mathcal{X}|$ should be super-poly)
- Unpredictability implies security against key recovery
- A secure block cipher must be secure against key recovery ($|\mathcal{K}|$ should be super-poly)

Secure PRF

Analogously we can define a secure PRF as a function which is computationally indistinguishable from a truly random function.

Attack Game (PRF)

F PRF over $(\mathcal{K}, \mathcal{X}, \mathcal{Y})$, For $b = 0, 1$, we define: Experiment b:

- chall. selects $f \in Funs[\mathcal{X}, \mathcal{Y}]$ as follows:
  - if $b = 0$: $k \xleftarrow{R} \mathcal{K}$, $f \leftarrow F(k, \cdot)$;
  - if $b = 1$: $f \xleftarrow{R} Funs[\mathcal{X}, \mathcal{Y}]$.
- adv. sends queries to chall. x_i and receive $y_i = f(x_i)$
- adv. output $\hat{b} \in \{0, 1\}$.

Let W_b be the event that $\mathcal{A}$ outputs 1 in Experiment b. We define $PRFadv[\mathcal{A}, F] = |Pr[W_0] - Pr[W_1]|$

Definition

F is secure if for all efficient adversaries $\mathcal{A}$, the value $PRFadv[\mathcal{A}, F]$ is negligible.

Is a PRP indistinguishable from a PRF?

Consider the 1-bit PRP from the previous question:

$$E(k, x) = x \oplus k$$

Is it a secure PRF?
Note that $Funs[X, X]$ contains four functions

Is a PRP indistinguishable from a PRF?

Consider the 1-bit PRP from the previous question:

$$E(k, x) = x \oplus k$$

Is it a secure PRF?
Note that $Funs[X, X]$ contains four functions
No
Attacker A:

(1) query $f(\cdot)$ at $x = 0$ and $x = 1$

(2) if $f(0) = f(1)$ output "1", else "0"

$PRFadv[A, E] = |0 - 1/2| = 1/2$

Is a PRP indistinguishable from a PRF?

Consider a distinguishing experiment between functions and permutations.

Observation: The only way to distinguish between a permutation and a non-permutation function is to find a collision, inputs so that $f(x_1) = f(x_2)$.

Theorem

An adversary that makes Q queries can distinguish a random permutation from a random function with probability at most $Q^2/(2|\mathcal{X}|)$.
In particular, let $\mathcal{E}$ be a PRP over $(\mathcal{K}, \mathcal{X})$

$$|PRFadv[\mathcal{A}, \mathcal{E}] - PRPadv[\mathcal{A}, \mathcal{E}]| < Q^2/2|\mathcal{X}|$$

Corollary

If $|\mathcal{X}|$ super-poly.

$$PRFadv[\mathcal{A}, \mathcal{E}] \text{ negl.} \Leftrightarrow PRPadv[\mathcal{A}, \mathcal{E}] \text{ negl.}$$

Secure encryption from PRP and PRF

Using PRPs and PRFs

Goal: build "secure" encryption from a PRP (or PRF).

Security is always defined using two parameters:

- What "power" does adversary have?
  Examples:
  - Adv sees only one ciphertext (one-time key)
  - Adv sees many PT/CT pairs (many-time key, CPA)
- What "goal" is adversary trying to achieve?
  Examples:
  - Fully decrypt a challenge ciphertext.
  - Learn info about PT from CT (semantic security)

Modes of operation: one time key

Using a block cipher directly for encryption

Question: is a secure block cipher also semantically secure?

Using a block cipher directly for encryption

Question: is a secure block cipher also semantically secure?

Answer: "yes", provided the message space is equal to the data block space

Using a block cipher directly for encryption

Question: is a secure block cipher also semantically secure?

Answer: "yes", provided the message space is equal to the data block space

If we want to encrypt longer messages?

Using a block cipher directly for encryption

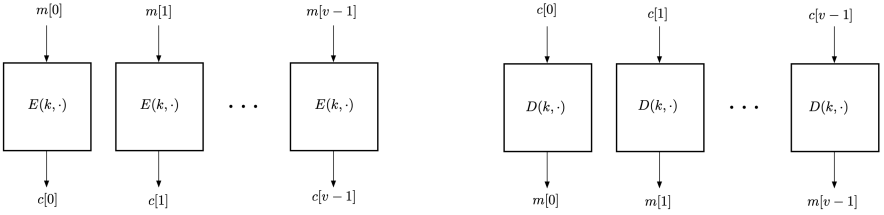
Question: is a secure block cipher also semantically secure?

Answer: "yes", provided the message space is equal to the data block space

If we want to encrypt longer messages?

Natural idea: break up a long message into a sequence of data blocks and encrypt each data block separately

electronic codebook mode (ECB)



(a) encryption

(b) decryption

ECB is insecure for multiple blocks

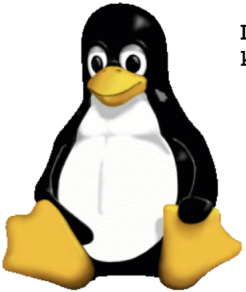
ECB is **not semantically secure** for messages that contain two or more blocks.

Let $\mathcal{E} = (Enc, Dec)$ be a block cipher (or PRP) over $(\mathcal{K}, \mathcal{X})$. Suppose to use ECB mode for encrypting plaintext composed by 2 blocks, i.e. $\mathcal{P} = \mathcal{X}^2$

- Adv. $\mathcal{A}$ send (m_0, m_0) and (m_0, m_1) to the challenger
- Ch. responses with $c_b = (c_b[0], c_b[1])$
- If $c_b[0] = c_b[1]$, $\mathcal{A}$ outputs 0, 1 otherwise.

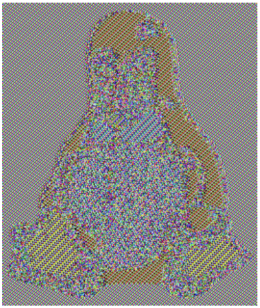
$SSadv[\mathcal{A}, ECB] = 1$.

ECB-AES



Linux penguin mascot
known as "Tux"

AES with ECB



Deterministic counter-mode (Det. CTR)

Let $\mathcal{X} = \{0,1\}^n$. Let F be a PRF over $(\mathcal{K}, \mathcal{X}, \mathcal{X})$, the **Deterministic counter-mode** (Det. CTR) encryption is the cipher $\mathcal{E}' = (Enc, Dec)$ defined over $(\mathcal{K}, \mathcal{X}^{\leq \ell}, \mathcal{X}^{\leq \ell})$ for which encryption and decryption work as:

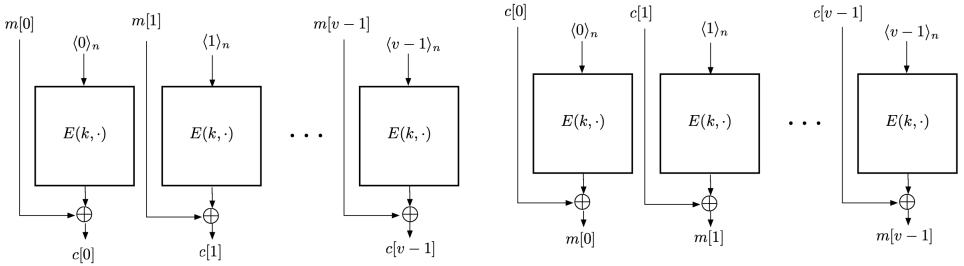
- for $k \in \mathcal{K}$ and $m \in \mathcal{X}^{\leq \ell}$, with $|m| = v$

$$Enc(k, m) = (F(k, 0_n) \oplus m[0], F(k, 1_n) \oplus m[1], ..., F(k, (v-1)_n) \oplus m[v-1])$$

- for $k \in \mathcal{K}$ and $c \in \mathcal{X}^{\leq \ell}$, with $|c| = v$

$$Dec(k, c) = (F(k, 0_n) \oplus c[0], F(k, 1_n) \oplus m[1], ..., F(k, (v-1)_n) \oplus c[v-1])$$

CRT mode



(a) encryption

(b) decryption

Note: Notice that if we use a BC only the encryption algorithm is used in both encryption and decryption

Theorem

Let $x_1, ..., x_\ell$ be fixed, distinct elements, and F be a secure PRF. $G(k) = (F(k, x_1), F(k, x_2), ..., F(k, x_\ell))$ is a secure PRG.

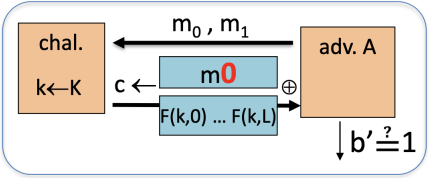
Corollary

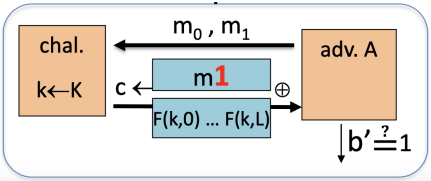
Det. CTR is semantically secure. In particular, for any eff. adversary $\mathcal{A}$ attacking $\mathcal{E}_{DETCTR}$ there exists an eff. PRF adversary $\mathcal{B}$ s.t.

$$SSadv[\mathcal{A}, \mathcal{E}_{DETCTR}] = 2 \cdot PRFadv[\mathcal{B}, F].$$

Proof by pictures

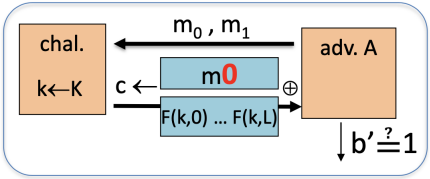
Game 0



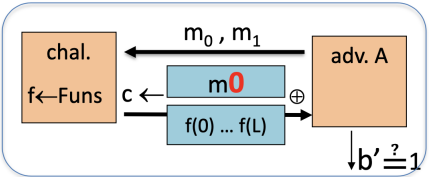


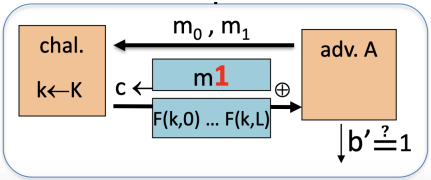
Proof by pictures

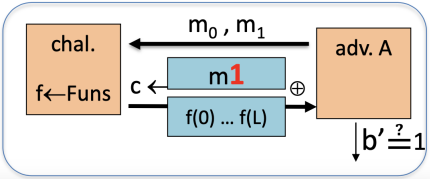
Game 0



Game 1

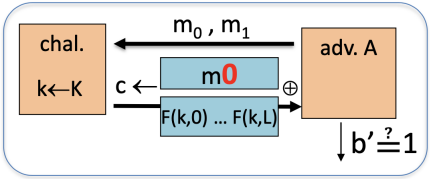






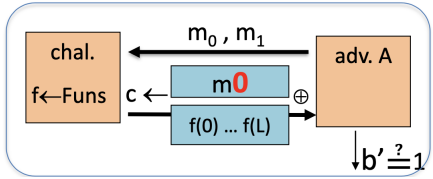
Proof by pictures

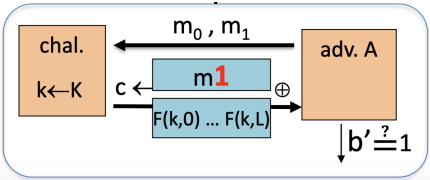
Game 0



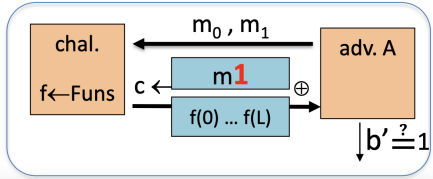
↔ ind. PRF

Game 1



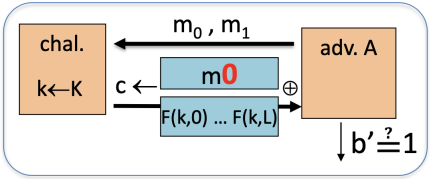


↔ ind. PRF



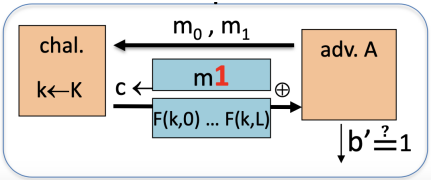
Proof by pictures

Game 0



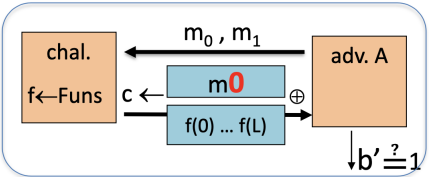
↔ ind. PRF

↕ ind. SS

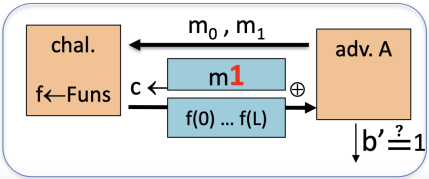


↔ ind. PRF

Game 1



↕ ind. SS



Remark

If we use a block cipher (PRP) $\mathcal{E}$ instead of a PRF F, then CTR is secure if $\ell^2/2^{n+1}$ is very small.

$$SSadv[\mathcal{A}, \mathcal{E}_{DETCTR}] = 2 \cdot PRPadv[\mathcal{B}, F] + \ell^2/2|\mathcal{X}|.$$

Adv. $\mathcal{A}$ can select $m_0 =$ "ℓ zero blocks", $m_1 =$ "ℓ random blocks". Encryption of m_0 with CTR does not contain any duplicated blocks. If we encrypt m_1, by the birthday paradox, the ciphertext will contain duplicate blocks with probability at least $\min\{\ell(\ell-1)/4N, 0.63\}$

Modes of Operation: many-time Key

Semantic Security for many-time key

CPA security

Attack Game (Chosen plaintext semantic security)

Let $\mathcal{E} = (Enc, Dec)$ over $(\mathcal{K}, \mathcal{P}, \mathcal{C})$, and consider an adversary $\mathcal{A}$. For b = 0,1, we define

Experiment b**:**

- The challenger computes $k \xleftarrow{R} \mathcal{K}$,
- $\mathcal{A}$ submits a sequence of queries to the challenger.
  For $i = 1, 2, ...,$ the ith query is a pair of messages, $m_{i0}, m_{i1} \in \mathcal{P}$, of the same length. The challenger computes $c_i \xleftarrow{R} Enc(k_i, m_{ib})$, and sends c_i to the adversary.
- $\mathcal{A}$ outputs a bit $\hat{b} \in \{0, 1\}$.

For $b = 0, 1$, let W_b be the event that $\mathcal{A}$ outputs 1 in Experiment b. We define $\mathcal{A}$'s advantage with respect to $\mathcal{E}$ as

$$CPAadv[\mathcal{A}, \mathcal{E}] := |Pr[W_0] - Pr[W_1]|.$$

Note: if $\mathcal{A}$ wants $Enc(k, m)$ it queries $m_{i0} = m_{i1} = m$.

Definition

$\mathcal{E}$ is semantically secure under CPA (IND-CPA) if for any efficient adversary $\mathcal{A}$ we have $CPAadv[\mathcal{A}, \mathcal{E}]$ is negligible.

Note: CPA Game can be recast as a "bit guessing" game.
$CPAadv^*[\mathcal{A}, \mathcal{E}] = |Pr[\hat{b} = b] - 1/2|$, and as usual
$CPAadv[\mathcal{A}, \mathcal{E}] = 2 \cdot CPAadv^*[\mathcal{A}, \mathcal{E}]$.

Remarks on CPA security

Theorem

No deterministic cipher can be CPA-secure.

Proof.

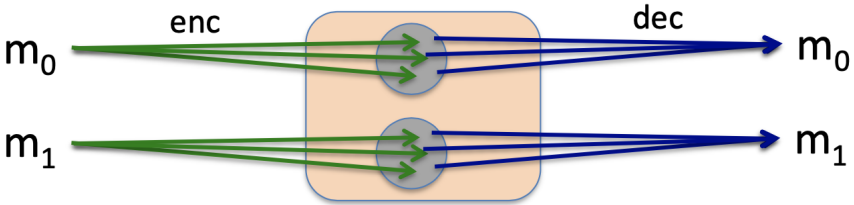
Adversary queries (m_0, m_1) then $(m_0, m_1' = m_0) \Rightarrow CPAadv[\mathcal{A}, \mathcal{E}] = 1$. $\square$

Note: If secret key is to be used multiple times $\Rightarrow$ given the same plaintext message twice, the encryption alg. must produce different outputs.

Randomized encryption

Randomized encryption

$Enc(k, m)$ is a randomized algorithm:



- encrypting same msg twice gives different ciphertexts (w.h.p)
- ciphertext must be longer than plaintext: CT-size = PT-size + "# random bits"

Cipher block chaining (CBC)

Let $\mathcal{E} = (Enc, Dec)$ be a BC over $(\mathcal{K}, \mathcal{X})$, where $\mathcal{X} = \{0,1\}^n$. Define a cipher $\mathcal{E}_{CBC} = (Enc', Dec')$, over $(\mathcal{K}, \mathcal{X}^{\leq \ell}, \mathcal{X}^{\leq \ell+1})$

Encryption:

for $k \in \mathcal{K}$ and $m \in \mathcal{X}^{\leq \ell}$, with $v := |m|$,

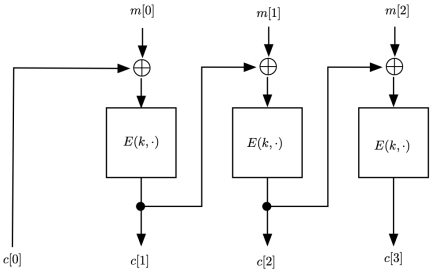
- compute $c[0] \xleftarrow{R} \mathcal{X}$
- for $i = 0, ..., v-1$, $c[i+1] = Enc(k, c[i] \oplus m[i])$
- output $Enc'(k, m) := (c[0], ..., c[v])$

Decryption:

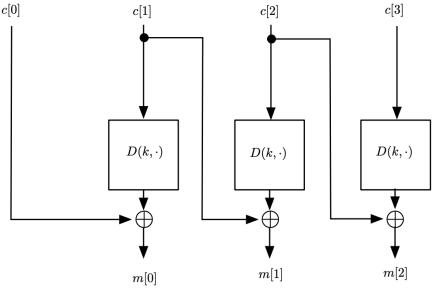
for $k \in \mathcal{K}$ and $c \in \mathcal{X}^{\leq \ell+1}$, with $v := |c| - 1$,

- for $i = 0, ..., v-1$, $m[i] = Dec(k, c[i+1]) \oplus c[i]$
- output $Dec'(k, c) := (m[0], ..., m[v-1])$

Note: $c[0]$ is also called initial value (IV).



(a) encryption



(b) decryption

CBC: CPA Analysis

Theorem

If $\mathcal{E}$ is a secure PRP over $(\mathcal{K}, \mathcal{X})$ then $\mathcal{E}_{CBC}$ is a sem. sec. under CPA over $(\mathcal{K}, \mathcal{X}^{\leq \ell}, \mathcal{X}^{\leq \ell+1})$.
In particular, for a Q-query adversary $\mathcal{A}$ attacking $\mathcal{E}_{CBC}$ there exists a PRP adversary $\mathcal{B}$ s.t.:

$$CPAadv[\mathcal{A}, \mathcal{E}_{CBC}] \leq 2 \cdot PRPadv[\mathcal{B}, \mathcal{E}] + 2\frac{Q^2 \ell^2}{|\mathcal{X}|}.$$

Remark

- *CBC is only secure as long as $Q^2 \cdot \ell^2 << |\mathcal{X}|$.*

An example

$$CPAadv[\mathcal{A}, \mathcal{E}_{CBC}] \leq 2 \cdot PRPadv[\mathcal{B}, \mathcal{E}] + 2\frac{Q^2\ell^2}{|\mathcal{X}|}.$$

$Q = \#$ messages encrypted with k , $\ell =$ length of max message

Suppose we want $CPAadv[\mathcal{A}, \mathcal{E}_{CBC}] \leq 1/2^{32}$, then $\frac{Q^2\ell^2}{|\mathcal{X}|} < 1/2^{32}$

- AES: $|\mathcal{X}| = 2^{128} \Rightarrow Q\ell < 2^{48}$

  So, after 2^{48} AES blocks, must change key!

- 3DES: $|\mathcal{X}| = 2^{64} \Rightarrow Q\ell < 2^{16}$

Attack on CBC with predictable IV

CBC where attacker can predict the IV is not CPA-secure,

Bug in SSL/TLS 1.0: IV for record #i is last CT block of record #(i-1)

Suppose that A, given $c = E_{CBC}(k, m)$ can predict IV for next message

Attack on CBC with predictable IV

CBC where attacker can predict the IV is not CPA-secure,

Bug in SSL/TLS 1.0: IV for record #i is last CT block of record #(i-1)

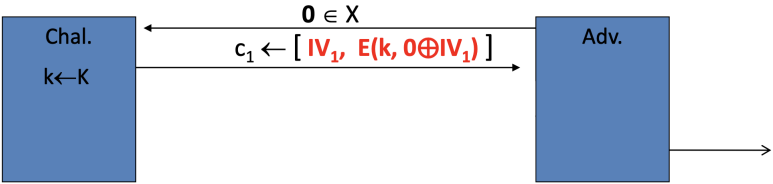
Suppose that A, given $c = E_{CBC}(k, m)$ can predict IV for next message

Attack on CBC with predictable IV

CBC where attacker can predict the IV is not CPA-secure,

Bug in SSL/TLS 1.0: IV for record #i is last CT block of record #(i-1)

Suppose that A, given $c = E_{CBC}(k, m)$ can predict IV for next message

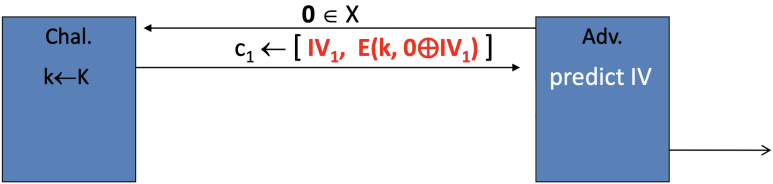


Attack on CBC with predictable IV

CBC where attacker can predict the IV is not CPA-secure,

Bug in SSL/TLS 1.0: IV for record #i is last CT block of record #(i-1)

Suppose that A, given $c = E_{CBC}(k, m)$ can predict IV for next message

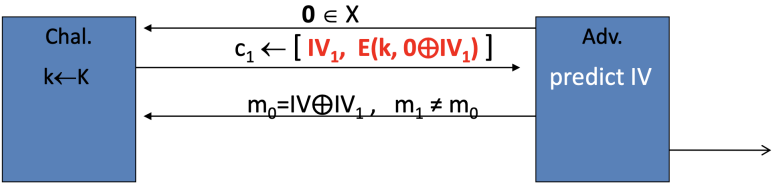


Attack on CBC with predictable IV

CBC where attacker can predict the IV is not CPA-secure,

Bug in SSL/TLS 1.0: IV for record #i is last CT block of record #(i-1)

Suppose that A, given $c = E_{CBC}(k, m)$ can predict IV for next message

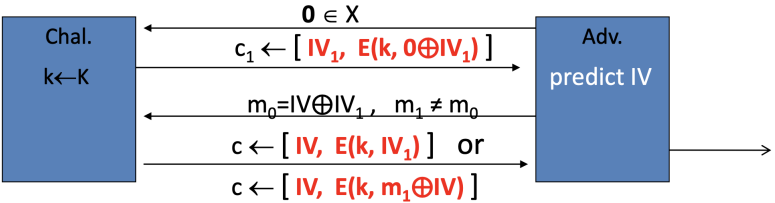


Attack on CBC with predictable IV

CBC where attacker can predict the IV is not CPA-secure,

Bug in SSL/TLS 1.0: IV for record #i is last CT block of record #(i-1)

Suppose that A, given $c = E_{CBC}(k, m)$ can predict IV for next message

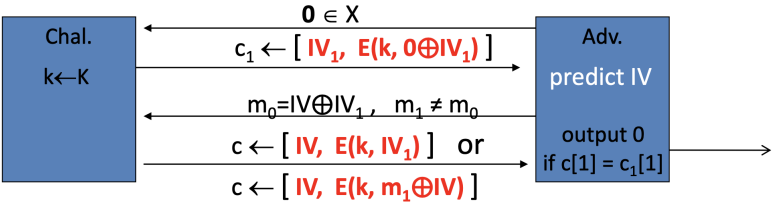


Attack on CBC with predictable IV

CBC where attacker can predict the IV is not CPA-secure,

Bug in SSL/TLS 1.0: IV for record #i is last CT block of record #(i-1)

Suppose that A, given $c = E_{CBC}(k, m)$ can predict IV for next message



A CBC technicality: padding

Q: How do you encrypt odd-length messages with a fixed-length block cipher?

A CBC technicality: padding

Q: How do you encrypt odd-length messages with a fixed-length block cipher?
A: Pad message somehow.

Example: PKCS#7 padding.

- If message is b bytes short of 128-bit block, append b bytes bbb . . . b to make block multiple of 128
- if no pad needed, add a dummy block
- Decryptor checks and strips off padding.

Q: What do you do if padding is incorrect?

A CBC technicality: padding

Q: How do you encrypt odd-length messages with a fixed-length block cipher?
A: Pad message somehow.

Example: PKCS#7 padding.

- If message is b bytes short of 128-bit block, append b bytes bbb . . . b to make block multiple of 128
- if no pad needed, add a dummy block
- Decryptor checks and strips off padding.

Q: What do you do if padding is incorrect?
A: Throw an error?

A CBC technicality: padding

Q: How do you encrypt odd-length messages with a fixed-length block cipher?
A: Pad message somehow.

Example: PKCS#7 padding.

- If message is b bytes short of 128-bit block, append b bytes bbb . . . b to make block multiple of 128
- if no pad needed, add a dummy block
- Decryptor checks and strips off padding.

Q: What do you do if padding is incorrect?
A: Throw an error?

Note: Vaudenay 2002: CBC mode encryption is insecure if attacker can distinguish bad from good message padding

rand CTR-mode

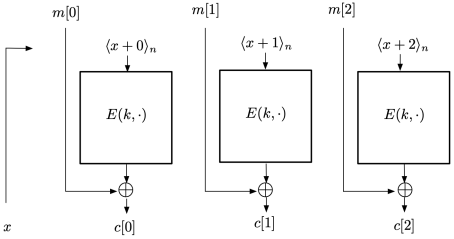
Let F be PRF over $(\mathcal{K}, \mathcal{X}, \mathcal{Y})$. $\mathcal{X} = \{0, ..., N-1\}$, $\mathcal{Y} = \{0,1\}^n$. We define $\mathcal{E}_{rndCTR} = (Enc, Dec)$ over $(\mathcal{K}, \mathcal{Y}^{\leq \ell}, \mathcal{X} \times \mathcal{Y}^{\leq \ell})$.
Encryption:
for $k \in \mathcal{K}$ and $m \in \mathcal{Y}^{\leq \ell}$,with $v := |m|$,

- compute $x \xleftarrow{R} \mathcal{X}$
- for $j = 0, ..., v-1$, $c[j] = F(k, x + j \mod N) \oplus m[j]$
- output $Enc(k, m) := (x, c[0], ..., c[v-1])$

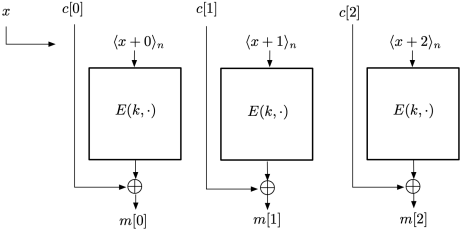
Decryption:
for $k \in \mathcal{K}$ and $c' = (x, c) \in \mathcal{X} \times \mathcal{Y}^{\leq \ell}$,with $v := |c|$,

- for $j = 0, ..., v-1$, $m[j] = F(k, x + j \mod N) \oplus c[j]$
- output $Dec'(k, c) := (m[0], ..., m[v-1])$

Note: x is also called initial value (IV).



(a) encryption



(b) decryption

rand CTR-mode: CPA analysis

Theorem

If F is a secure PRF over $(\mathcal{K}, \mathcal{X}, \mathcal{Y})$ then $\mathcal{E}_{rndCTR}$ is a sem. sec. under CPA. In particular, for a Q-query adversary $\mathcal{A}$ attacking $\mathcal{E}_{rndCTR}$ there exists a PRF adversary $\mathcal{B}$ s.t.:

$$CPAadv[\mathcal{A}, \mathcal{E}_{rndCTR}] \leq 2 \cdot PRFadv[\mathcal{B}, F] + 2\frac{Q^2\ell}{|\mathcal{X}|}$$

Note: rand. CTR-mode only secure as long as $Q^2\ell << |\mathcal{X}|$. (Better than CBC!)

An example

$$CPAadv[\mathcal{A}, \mathcal{E}_{rndCTR}] \leq 2 \cdot PRFadv[\mathcal{B}, F] + 2\frac{Q^2\ell}{|\mathcal{X}|}$$

$Q = \#$ messages encrypted with k , $\ell =$ length of max message

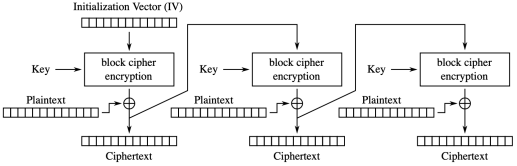
Suppose we want $CPAadv[\mathcal{A}, \mathcal{E}_{CBC}] \leq 1/2^{32}$, then $\frac{Q^2\ell}{|\mathcal{X}|} < 1/2^{32}$

- AES: $|\mathcal{X}| = 2^{128} \Rightarrow Q\sqrt{\ell} < 2^{48}$

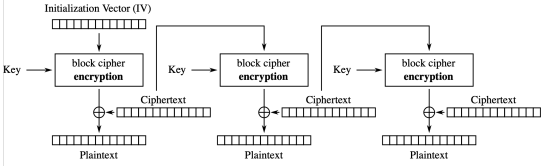
So, after 2^{32} CTs of length 2^{32}, must change key!
(total of 2^{64} AES blocks)

Other modes

Cipher Feedback (CFB)



Cipher Feedback (CFB) mode encryption

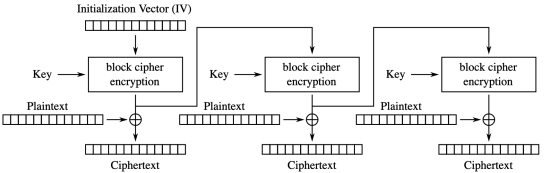


Cipher Feedback (CFB) mode decryption

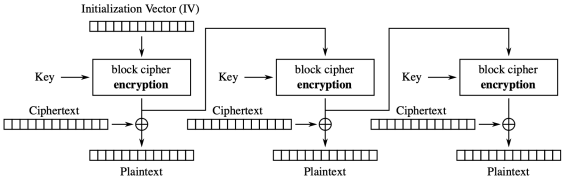
- very similar to a stream cipher
- only the encryption algorithm is used in encryption and decryption

Other modes

Output Feedback (OFB)



Output Feedback (OFB) mode encryption



Output Feedback (OFB) mode decryption

Note: we can use a PRF instead of a BC

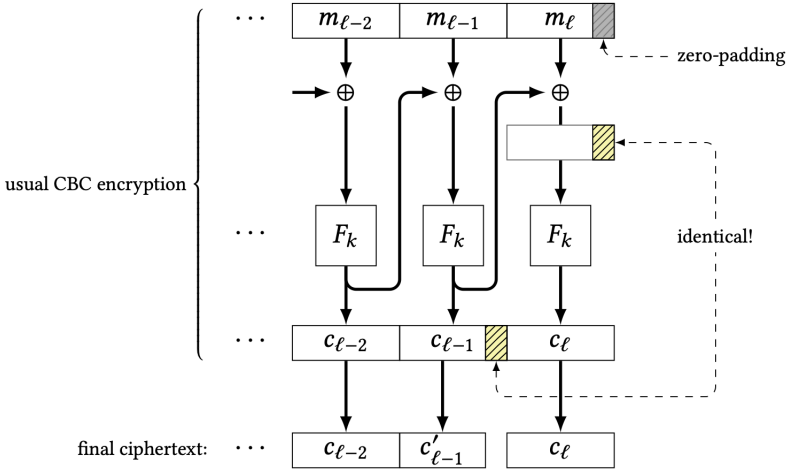
- similar to the CFB mode
- As for CFB, only the encryption algorithm is used in both encryption and decryption

Comparison: ctr vs. CBC

	CBC	ctr mode
uses	PRP	PRF
parallel processing	No	Yes
Security of rand. enc.	Q^2 L^2 << |X|	Q^2 L << |X|
dummy padding block	Yes	No

(for CBC, dummy padding block can be solved using ciphertext stealing)

ciphertext stealing (CTS)



Summary

- PRPs and PRFs: a useful abstraction of block ciphers.
- We examined two security notions: (security against eavesdropping)
  1. Semantic security against one-time CPA.
  2. Semantic security against many-time CPA.

  Note: neither mode ensures data integrity.
- Stated security results summarized in the following table:

Goal \ Power	**one-time key**	**Many-time key (CPA)**	**CPA and integrity**
Sem. Sec.	steam-ciphers det. ctr-mode	rand CBC rand ctr-mode	later